

PART 6 OF 18

Identity Architecture for AI Agents

Workload Identity, SPIFFE/SPIRE, Ephemeral Credentials, Delegation Chains, Cloud-Native IAM Patterns, and Zero Trust Identity for Autonomous Systems

ENTERPRISE AI CONTROL ARCHITECTURE

Implementation Guide for Production AI Systems • 2026

6.1 Why AI Agents Need a New Identity Model

Traditional enterprise identity serves humans and static software systems. Human identity is persistent, strongly authenticated (MFA), and carries accountability through legal personhood. Service account identity is persistent, weakly authenticated (API key or certificate), and carries organizational accountability through ownership assignment. Neither model fits autonomous AI agents, which are: dynamically instantiated, exhibit variable behaviour, operate across multiple trust domains, may delegate to sub-agents, and require fine-grained, task-scoped permissions that change throughout the agent lifecycle.

6.1.1 The AI Agent Identity Requirements

Requirement	Description	Why Different from Traditional
Hierarchical Identity	Identity at platform, type, instance, and task levels	No equivalent in human or service account identity models
Task-Scoped Permissions	Permissions change with task context, not statically assigned	RBAC assumes static roles; agents need dynamic capability assignment
Delegation Tracking	Record which human principal authorized the agent's current task	Service accounts don't carry delegation chain metadata
Session Binding	Identity bound to specific execution session, not perpetual	Service accounts persist indefinitely; agent sessions are ephemeral
Cross-Domain Trust	Agent identity recognizable across enterprise service boundaries	Service accounts are typically domain-local
Behavioral Attestation	Identity includes attestation of behavioral baseline compliance	No concept in any existing identity system

6.2 SPIFFE/SPIRE for Agent Workload Identity

SPIFFE (Secure Production Identity Framework for Everyone) and its reference implementation SPIRE provide the most appropriate foundation for AI agent workload identity. SPIFFE assigns cryptographically verifiable identities (SVIDs—SPIFFE Verifiable Identity Documents) to workloads running in any environment, and SVIDs are automatically rotated with short TTLs.

6.2.1 SPIFFE SVID Structure for AI Agents

Standard SPIFFE SVIDs use the format: `spiffe://trust-domain/path`. For AI agents, the path component encodes the agent hierarchy:

■ Example SVID Paths:

spiffe://corp.example.com/platform/langgraph/v2 (platform identity)

spiffe://corp.example.com/agent/finance-analyst/v1.3 (agent type identity)

spiffe://corp.example.com/agent/finance-analyst/instance/sess-a7f2b1 (session identity)

spiffe://corp.example.com/agent/finance-analyst/task/task-8c3d9e (task identity)

6.2.2 SPIRE Deployment for Enterprise AI

- **SPIRE Server:** Centralized certificate authority and registration database; runs in HA configuration in enterprise PKI infrastructure
- **SPIRE Agent:** Node-level daemon that handles SVID issuance to workloads on that node; runs in agent orchestration hosts
- **Workload API:** Unix domain socket through which AI agent processes obtain their SVIDs without secrets in environment
- **Node Attestation:** Verifies the identity of the compute node before issuing SVIDs (AWS IID, Azure MSI, K8s node attestation)
- **Workload Attestation:** Verifies the AI agent process identity through container metadata, process attributes, or custom attestors
- **SVID Rotation:** SVIDs rotate automatically every 1-5 hours; agent processes receive new SVIDs through Workload API without restart

6.3 Cloud-Native Identity Patterns

6.3.1 AWS Identity for AI Agents

AWS provides the richest set of identity primitives for AI agent deployments. The recommended pattern uses IAM Roles for EKS service accounts (IRSA) or ECS task roles for container-based agents, with STS AssumeRole for task-specific permission scoping.

Pattern	Use Case	Implementation	TTL
IAM Role (IRSA)	Kubernetes-hosted agents	ServiceAccount annotation + OIDC federation	15 min – 12 hours
ECS Task Role	Container-based agents	Task definition IAM role association	Session duration
STS AssumeRole	Task-specific permission scoping	Assume role per task with inline session policy	15 min – 1 hour
IAM Roles Anywhere	Non-cloud or hybrid agents	X.509 cert from PKI + Roles Anywhere profile	Up to 12 hours
Cognito Federated ID	User-context delegation	User pool token exchanged for IAM credentials	1 hour
AWS Verified Access	Agent service access control	Access policy with trust provider	Session-based

6.3.2 Azure Identity for AI Agents

Azure Entra ID Workload Identity Federation provides OIDC-based identity for AI agents running in Azure Kubernetes Service, Container Apps, or Azure Functions. Managed Identities provide automatic credential management without secrets for agents running on Azure compute.

Pattern	Use Case	Key Benefit
System-assigned Managed Identity	Single-service agents on Azure compute	Zero secret management; tied to resource lifecycle
User-assigned Managed Identity	Agents requiring shared identity or cross-resource identity	Identity portable across resources; explicit lifecycle
Workload Identity Federation (AKS)	Kubernetes-hosted agents	No secrets; OIDC federation with service principal
Federated Identity Credential	Agents in external environments (GitHub Actions, AWS)	Cross-cloud identity without credential exchange

6.3.3 Google Cloud Identity for AI Agents

- **Workload Identity Federation:** Allows agents in non-GCP environments to use short-lived tokens instead of service account keys
- **Service Account Impersonation:** Agents use their SPIFFE identity to impersonate specific service accounts with limited permissions
- **Binary Authorization:** Enforce that only attested container images (including agent containers) can access GCP services
- **Workforce Identity Federation:** For agents acting on behalf of human users, their access tokens can be exchanged for GCP-scoped tokens

6.4 Delegation Chain Architecture

When a human user authorizes an agent to act on their behalf, that authorization must be tracked through a cryptographically verifiable delegation chain. This is essential for audit (who authorized this action?), access control (does the agent have the human's permission for this specific action?), and accountability (who is responsible if the action causes harm?).

6.4.1 Delegation Token Structure

■ JWT Delegation Chain Example: Header: {alg: RS256, kid: 'enterprise-signing-key-2026-03'}
Payload: { delegator: 'user:alice@corp.example.com', delegatee: 'agent:finance-analyst/sess-a7f2b1', scope: ['read:financial-reports', 'write:draft-analysis'], max_delegation_depth: 1, task_description: 'Prepare Q2 earnings analysis', iat: 1750000000, exp: 1750086400, constraints: {data_classification: 'CONFIDENTIAL', output_only_to: 'alice@corp.example.com'} }

6.4.2 Delegation Chain Rules

- Delegation depth is limited (default max: 2 levels); sub-agents cannot re-delegate without explicit grant
- Each delegation token encodes the task scope; agents cannot use delegation tokens for tasks outside declared scope
- Delegation tokens are irrevocable until expiry but can be preemptively invalidated through revocation list

- Human-to-agent delegation requires explicit human confirmation; agent-to-agent delegation inherits parent constraints
- All delegation events are logged with full token payload in the immutable audit store

6.5 Capability-Based Security for Fine-Grained Agent Authorization

Traditional RBAC is insufficient for AI agents because roles are too coarse-grained. Capability-based security assigns specific, unforgeable tokens (capabilities) that grant access to specific resources or operations. Unlike ACL-based systems, capabilities are held by the agent—no external lookup is needed, reducing attack surface and latency.

6.5.1 Capability Token Architecture

Capability Type	Grants	Issued By	Validity
Read Capability	Read access to specific resource or data scope	Capability Broker at task start	Task duration
Write Capability	Write access to specific resource with defined impact limit	Capability Broker with human approval for sensitive writes	Single use or task duration
Tool Invocation Capability	Right to invoke specific tool endpoint	Tool Registry at capability request	Task duration
Delegation Capability	Right to delegate to sub-agent with constrained scope	Human principal or elevated agent	Single delegation event
Memory Access Capability	Read/write access to specific memory namespace	Memory Governor	Task or session duration